ApproveHub

Solutions and hardening plan

A fix for every problem found in the review, plus 14 more we discovered.
Each fix lists what could still go wrong. Nothing here claims to be perfect.

October 2026 - Not legal advice: have a lawyer review the legal and privacy sections before launch.

Read this first

You asked for solutions with no bugs, loopholes or problems. I cannot honestly promise that, and neither can anyone. Real systems are always attacked, misused and misunderstood in ways nobody predicted. What a good design can do is make attacks hard, make misuse visible, and make mistakes fixable. That is what this document does.

How each problem is written

Every item has four parts: the **problem**, the **solution**, and a **residual risk**, which is what can still go wrong after the fix. If you see a residual risk of None, I could not think of a meaningful one. That is not proof there is none.

Where I am unsure

I am not a lawyer. The legal and privacy points (Section 2 and V1) were checked against general sources, not against your institution or your documents. A lawyer must confirm them. The legal points on electronic signatures rest on a search of public explainers and should be confirmed against the Act itself.

What this changes about the product

Three changes matter most: nobody can choose their own role, marks are applied only by the server after a device-signed approval, and every document is locked and hashed when sent. Most other fixes follow from these three.

Contents

1	The big picture: trust levels, request states, rules that never break
2	Trust, legality and identity (T1 to T8)
3	Admin control and hierarchy (H1 to H3, D1)
4	Workflow (P1 to P9)
5	Security (S1 to S5)
6	Privacy, tenants, adoption and verification (V1 to V4)
7	Design and UX fixes (U1 to U10)
8	Screens that must still be designed
9	Additional problems found (A1 to A14)
10	Build order
11	Decisions for you and the launch checklist
12	Closing note

1. The big picture

Three ideas that hold the rest together.

Assurance levels

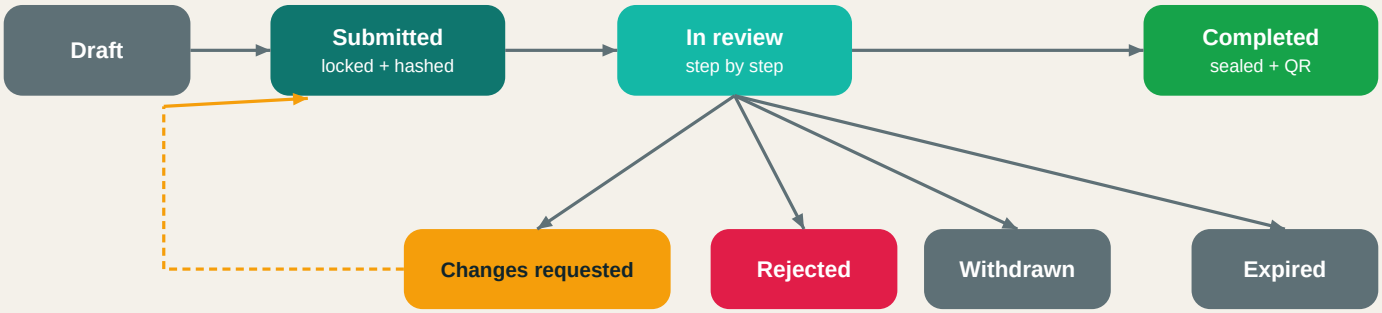
LEVEL 1
Institutional approval
Image mark + sealed audit trail. Internal papers.

LEVEL 2
Aadhaar eSign
Licensed provider. Legally recognised e-signature.

LEVEL 3
DSC token signing
Regulatory-grade. Courts, banks, government filings.

Higher level = stronger legal standing, more steps for the user. The document type decides the level.

Request life cycle



Edit after Changes requested creates a new version. Approvals restart from the first affected step.
Rejected, Withdrawn and Expired are final. Nothing is ever deleted: marks on a withdrawn request are shown as voided.

Rules the system must always enforce

1. No one approves a request they created, are the subject of, or whose chain they recently changed.
2. A mark is applied only by the server, and only after an approval signed by the approver registered device key.
3. Roles are assigned by the institution, never chosen by the person.
4. A sent document is locked. Any change makes a new version and restarts approvals from the affected step.
5. Every action goes into an append-only, hash-chained audit log.
6. Admins see metadata, not document contents, unless a logged break-glass process is used.
7. Every grant of power has an expiry date.
8. A seal can be used only by the current holder of that office.
9. All times come from the server.
10. Nothing is hard-deleted. People, roles and offices are archived. Document content follows the retention rule.
11. The assurance level is always visible, on screen and on the final PDF.
12. Notifications never contain document content.

2. Trust, legality and identity

Why a signed document can be believed, and who is allowed to sign.

T1 Image marks have weak legal standing

PROBLEM A pasted signature image does not by itself meet the IT Act Section 3A test for an electronic signature, so some receivers may reject it.

SOLUTION

- Define three clearly labelled assurance levels. Level 1: institutional approval (image mark plus a sealed audit trail) for internal papers. Level 2: Aadhaar eSign through a licensed provider. Level 3: DSC-token signing for regulatory-grade documents.
- Do not build eSign yourself. Integrate a licensed eSign service provider for Levels 2 and 3. The document type decides which level is required.
- Show the level as a badge on every request, every screen and the final PDF, so nobody assumes more protection than they have.
- On completion, seal the final PDF with an institution-level digital signature so any later edit shows as a broken signature in a normal PDF reader.

RESIDUAL RISK Level 1 is still not a statutory e-signature. It is only suitable where the receiving party accepts institutional approval. Get a lawyer opinion for each document type.

T2 Signature images can be copied

PROBLEM Your whole trust model is a stored picture plus a PIN. If the picture leaks, anyone can paste it.

SOLUTION

- Store each authority mark encrypted on the server. It is never sent to any phone or browser; apps show only a low-resolution watermarked preview.
- Apply marks only on the server, at completion, together with a printed line next to the mark: approver name, role, date and time, request ID.
- Every final PDF carries a QR code and a short code that open the public verification page (see V4).
- Replacing a stored mark requires re-verification and creates a new version; old documents keep the version used.

RESIDUAL RISK Anyone holding a final PDF can still copy the picture, but a copied mark will not carry a valid ID line or pass verification. This only helps if recipients actually verify.

T3 Stamps and seals are personal uploads

PROBLEM Any authority can upload any stamp image. A seal belongs to an office, not a person, and is easy to forge.

SOLUTION

- Seals and stamps are office assets uploaded only by the institution owner after checking the original. A new seal needs a second person to confirm.
- An authority can apply an office seal only while holding that office role. Access ends automatically when the role ends.
- Every use of a seal is logged: who, when, which request. Seals are versioned and revocable.

RESIDUAL RISK A forged image could still be accepted at upload time if the two reviewers are careless.

T4 Documents with legal exceptions

PROBLEM Some documents cannot be validly signed electronically, or need a specific method.

SOLUTION

- Add a legal-check record to every document type, filled in with the institution lawyer: allowed level, whether wet ink is required, retention period.
- If wet ink is required, the app produces a print-ready version and tracks the physical signing as a manual step.
- Show a plain-language warning to the student when they pick a restricted type.

RESIDUAL RISK Laws and rules change. The table needs a yearly review by a lawyer.

T5 Anyone can claim to be an authority or admin

PROBLEM My signup screen lets a person pick their own role. A student could register as a HOD and approve their own request.

SOLUTION

- Remove the role picker. Roles are assigned, never chosen.
- Authorities join only by invitation to their official email or mobile, from a roster the institution supplies, linked to an employee ID.
- Students verify with an institutional email OTP or an enrolment-number roster supplied by the admin.
- Anyone outside the roster stays in a pending-verification state: they can look around but cannot send or approve anything.

RESIDUAL RISK Depends on the roster being correct and on institutional email accounts being secure.

T6 Who verifies the first admin?

PROBLEM The design has no answer. A fake institution admin controls the entire hierarchy.

SOLUTION

- Onboard institutions manually at first: official domain email check, a letter from the principal or registrar, and a verification call.
- Require at least two owners per institution. Removing the last owner is blocked.
- Keep a documented break-glass recovery process, owned by ApproveHub support, with identity checks.

RESIDUAL RISK Manual checks cost time and can be fooled by good forgeries. Keep the pilot list small and check each one personally.

T7 Ambiguous names

PROBLEM Two people can share a name, and a dropdown of names is error-prone.

SOLUTION

- Pickers show photo, employee ID, department, role and email handle.
- Search by role first (for example HOD, IT). Role-based routing (D1) picks the current holder automatically, so most users never pick a name.

RESIDUAL RISK Small. Wrong picks are still handled by the Not the right person action (P8).

T8 Spam, abuse and malicious files

PROBLEM Anyone can flood an authority, or upload a harmful file.

SOLUTION

- Accept only PDF, DOCX and images with a size limit. Scan every upload for malware. Flatten PDFs and strip scripts.
- Rate-limit per student, including a cap on open requests.
- Authorities can mute a sender or report abuse. Admins can suspend accounts.

RESIDUAL RISK A determined attacker with many valid accounts can still send many requests. Roster-only signup limits this.

3. Admin control and hierarchy

Who can change the structure, and how the structure is modelled.

H1 A delegated admin can rewrite the hierarchy

PROBLEM A delegate could make themselves HOD and approve their own papers.

SOLUTION

- Replace one admin role with scoped roles: Owner, Branch manager (one branch only), Authority manager, Auditor (read only).
- Every grant has an expiry (default 90 days) and shows who granted it.
- Sensitive changes (new HOD, new seal, changed chain) need a second person to confirm.
- Conflict rule: nobody can approve a request they created, are the subject of, or whose chain they changed in the last 24 hours.
- Withdrawing access needs a confirmation and ends that person sessions immediately.

RESIDUAL RISK Two colluding owners can still do harm. The audit log and alerts to the institution head are the backstop.

H2 Deleting a branch or person mid-request

PROBLEM Pending requests would be orphaned.

SOLUTION

- Never hard-delete. People and offices are archived with an end date.
- Archiving is blocked while requests are pending, until they are reassigned. The admin sees the list with one-click reassign.
- Each request keeps a snapshot of the hierarchy as it was when sent.

RESIDUAL RISK Reassigning many requests takes admin time.

H3 The hierarchy model is too simple

PROBLEM Branch, designation, person does not cover a Dean across branches, the exam cell, accounts, one person with two roles, or an HOD who changes each term.

SOLUTION

- Model offices (Dean Academics, Exam Cell, Accounts), roles (HOD IT) and positions held by people with start and end dates.
- One person can hold several roles, and a role can have an acting holder. Offices can sit across branches.
- Each mark records the role and the holder at that moment, so old documents stay correct after changes.

RESIDUAL RISK Setup is more complex. Ship starter templates for a typical college structure.

D1 Students pick approvers freely, with no policy

PROBLEM Nothing stops a leave letter going to the wrong person, or skipping a required one.

SOLUTION

- Admins define document types (bonafide, leave, NOC and so on). Each has a mandatory chain written as roles, optional extra approvers, allowed mark types, attachments and a time limit.
- The student picks a type and the chain fills itself in with the current role holders. They can add approvers but not remove mandatory ones.
- A free-form chain is allowed only if the type says so.

RESIDUAL RISK Admins must create the types. Provide starter types so day one works.

4. Workflow

What happens to a request, from sending to sealing.

P1 Requester controls mark placement

PROBLEM A requester could put a mark over text, and the authority cannot move it.

SOLUTION

- Standard forms use box positions defined by the admin (for example an HOD box at the bottom right), so the student places nothing.
- For custom documents, detect text areas and suggest blank zones. Warn or block when a mark would cover text. Marks cannot overlap each other.
- The authority sees the exact final render and may nudge or resize their own mark before approving. The requester is notified.

RESIDUAL RISK Detection can fail on scanned pages. The authority check is the final safeguard.

P2 No document lock or versioning

PROBLEM A file could be swapped after approval.

SOLUTION

- At send, the file is stored read-only with a SHA-256 hash and a version number. The ID is printed in the footer of the final PDF.
- Any change creates a new version. Earlier approvals are marked as given on a previous version and the chain restarts from the first affected step.
- Authorities always see the version number in the header.

RESIDUAL RISK A user may upload the wrong file. Withdraw and resubmit covers that.

P3 Only sequential approval

PROBLEM Real life needs parallel, any-one-of and quorum approvals.

SOLUTION

- Each step has a mode: sequential, parallel, any one of, or N of M.
- Validate at creation to prevent deadlocks (for example N cannot exceed M).

RESIDUAL RISK More complexity. Start with sequential plus any-one-of and add the rest later.

P4 No return, resubmit, withdraw or comments

PROBLEM Reject is a dead end.

SOLUTION

- Add states: Changes requested (comments pinned to a spot on a page), Rejected (final), Withdrawn, Expired.
- Resubmit creates a new version linked to the old one. History is kept.
- The requester can withdraw before completion. Marks already applied are voided and shown as voided.

RESIDUAL RISK Needs very clear wording so students understand which state they are in.

P5 No substitute, leave or escalation

PROBLEM If a professor is away or has left, the request waits forever.

SOLUTION

- Authorities set out-of-office with a named delegate and dates. Routing sends requests to the acting holder.
- The mark reads for Dr. R. Patil (HOD), signed by Prof. X, so the delegation is visible on the document.
- Delegations end automatically, with a 30-day maximum and an alert to the owner.
- A vacated role routes to the office inbox. Admins can reassign stuck requests, and it is logged.

RESIDUAL RISK Delegations can be misused. The maximum length and owner alerts limit this.

P6 No reminders, deadlines or bulk approve

PROBLEM Authorities receive many requests.

SOLUTION

- Reminder after 24 hours, escalation after 48 hours to the next level or the admin. A stuck-requests dashboard for admins.
- Bulk approve only for low-risk types: maximum 20 at once, with previews, one PIN. Never for Level 2 or 3.

RESIDUAL RISK Bulk approve encourages rubber-stamping. See P9.

P7 Approve is too blunt

PROBLEM Real approvals can be recommend, forward or approve with conditions, and usually need a remark and a date.

SOLUTION

- Actions: Approve, Recommend, Forward, Approve with conditions, Return, Reject. Each chain step lists which are allowed.
- Optional remarks and an automatic date and time printed with the mark.

RESIDUAL RISK None significant.

P8 Student picked the wrong person

PROBLEM The recipient has no way out.

SOLUTION

- Add a Not the right person action. It returns the request to the student, or forwards it to a suggested role with a note.

RESIDUAL RISK None significant.

P9 Approving without reading

PROBLEM An authority could approve in one tap without opening the document.

SOLUTION

- The Approve button turns on only after every page has been viewed (tracked). The audit log records which pages were seen.
- Optional minimum review time for important types. Remarks field available.

RESIDUAL RISK You can encourage reading but never force it.

5. Security

Keeping approvals safe if a phone or password is stolen.

S1 A 4-digit PIN is weak

PROBLEM Only 10,000 combinations, and attempt limits, lockout and device binding are undefined.

SOLUTION

- The PIN (6 digits by default; alphanumeric option for authorities) unlocks a hardware-backed key inside the phone. The PIN itself is never sent to the server.
- Five wrong tries cause a growing delay. Ten require full login plus OTP.
- Every approval is a signed challenge from that device key. The server rejects approvals without it.
- The app locks after 5 minutes idle. Biometrics are optional.

RESIDUAL RISK Someone who steals an unlocked phone and learned the PIN can still approve. Alerts and remote revoke limit the damage.

S2 Forgot PIN, lost phone, new device

PROBLEM None of these flows exist.

SOLUTION

- Forgot PIN: password plus OTP, then a new PIN and a new device key. Authority resets notify the admin.
- New device: password plus OTP. Other devices get a notification. Authorities have a 24-hour cooling-off before approving on a new device, which an admin can shorten after checking.
- A device list with remote revoke on the web. A lost-phone flow through the web or support.

RESIDUAL RISK SIM-swap attacks can defeat OTP. Offer passkeys or an authenticator app, and require one for authorities.

S3 Account compromise means stolen signature

PROBLEM Whoever gets into an HOD account could sign for them.

SOLUTION

- Combine S1 and S2: a device key is needed for every approval, so a password alone is not enough.
- Alerts and an extra confirmation for unusual approvals (odd hours, new place, many in a row).
- An emergency freeze button on the web and through support that blocks all approvals immediately.

RESIDUAL RISK No system fully stops a user who is tricked into approving. Training and alerts reduce the risk.

S4 Web login security

PROBLEM Web has no phone key.

SOLUTION

- Use passkeys (WebAuthn) as the device key on the web. Short sessions, re-authentication for approvals, and standard protections against session theft.

RESIDUAL RISK Passkey loss needs a recovery path (S2).

S5 Audit log can be tampered with

PROBLEM Logs are only useful if nobody can quietly edit them.

SOLUTION

- Append-only log. Each entry includes the hash of the previous one, forming a chain. Periodically store the latest hash with an outside timestamp service.
- Read-only exports for auditors.

RESIDUAL RISK A full-system compromise is still serious. Outside anchoring makes silent edits detectable.

6. Privacy, tenants, adoption and verification

Data protection, separation between institutions, getting people to use it, and checking printed copies.

V1 Privacy and data law

PROBLEM Documents hold personal data. India has the DPDP Act 2023, and some students may be under 18.

SOLUTION

- Show a purpose notice at upload. Collect only what is needed.
- Encrypt in transit and at rest, with a separate key per institution. Store data in India.
- Admins see request details (who, when, status) but not document contents by default.
- Retention per document type with automatic deletion. Export and deletion requests. A named grievance contact. A written breach-response plan.
- Check with a lawyer what rules apply for users under 18.

RESIDUAL RISK Compliance is an ongoing legal duty, not a feature you finish. Get legal review before launch.

V2 Tenant isolation

PROBLEM One institution must never see another.

SOLUTION

- Put a tenant ID on every record and enforce it in the database with row-level rules.
- Use separate encryption keys per tenant, and write automated tests that try cross-tenant reads.
- One person identity with separate memberships and an institution switcher.
- An independent penetration test before launch.

RESIDUAL RISK Bugs are always possible. Testing and keeping the pilot small reduce the impact.

V3 Adoption and business model

PROBLEM Colleges already have ERPs and tools such as Adobe Sign. The app is useless until authorities adopt it, and they are the least eager users.

SOLUTION

- Pilot with one department and three document types.
- Sign in with the existing college Google or Microsoft account. Import rosters instead of retyping.
- Let authorities approve from a secure link in email or WhatsApp with a passkey or biometric, without installing anything.
- Before building more, interview about 5 professors and 20 students. Decide pricing only after real costs are known.

RESIDUAL RISK Unproven demand is the biggest risk, and no design removes it. Only real users can.

V4 Printing and QR verification

PROBLEM Many offices still want paper, and a QR with no verification page is useless.

SOLUTION

- Each final PDF has a QR and an 8-character code that open a public page on your official domain.
- The page shows status, document ID, approvers and times, never content. It can also compare an uploaded copy with the stored hash.
- States: valid, revoked, superseded, not found. Rate-limited.

RESIDUAL RISK Recipients who never scan cannot be protected. Fake QR codes are possible, so show the domain and teach people to check it.

7. Design and UX fixes

Fixes to the screens and the way people use them.

U1 Missing pages and states

PROBLEM The PDF only shows the happy path.

SOLUTION

- Every screen gets empty, loading, error, offline and no-permission states, with a written copy deck.
- The missing screens are listed in the table in section 8, with rules for each.

RESIDUAL RISK None once delivered.

U2 Dragging marks on a phone

PROBLEM The preview is tiny, the finger hides the target, and this is your core feature.

SOLUTION

- A full-screen placement editor: pinch to zoom, tap to place, drag with a magnifier above the finger, resize and rotate handles, snap to grid and suggested zones, nudge arrows, undo and redo.
- On web: drag plus arrow keys and numeric fields for exact position.

RESIDUAL RISK Needs real testing on small phones with real users.

U3 Page size, multiple pages, printable area

PROBLEM I drew one fake A4 page.

SOLUTION

- Convert uploads to PDF on the server. Show a page strip. Marks are placed per page. Support A4, Letter and custom sizes.
- Compute the printable area from detected margins. Handle rotated pages. Option to add initials on every page.

RESIDUAL RISK Poor scans can confuse detection. The authority check remains.

U4 Contrast and colour-only meaning

PROBLEM White text on amber is only about 2:1, which fails accessibility guidelines. Authority colours rely on colour alone.

SOLUTION

- Use dark text on amber, and white text only on teal, navy or violet. Check every pair to the 4.5:1 AA level.
- Authorities are also identified by shape, number and label, never colour alone.

RESIDUAL RISK Check again after every palette change.

U5 Small text and older authorities

PROBLEM Many authorities are older and less used to apps.

SOLUTION

- Minimum 16 px body text on mobile and 14 px on web, a text-size setting, and 44 px touch targets.
- A Simple mode for authorities: one document, three big buttons (Approve, Return, Reject).

RESIDUAL RISK Test with at least five older faculty on real phones.

U6 Placeholder icons

PROBLEM The nav icons are dots.

SOLUTION

- Adopt one consistent icon set at 24 px with text labels beside every icon.

RESIDUAL RISK None.

U7 Destructive actions without confirmation

PROBLEM Delete, withdraw and reject happen in one tap.

SOLUTION

- A confirm dialog that states the consequence. Type-to-confirm for deleting offices or roles. A 10-second undo toast. Soft delete everywhere.

RESIDUAL RISK None.

U8 Admin navigation

PROBLEM The app shows only 5 of the 6 admin tabs.

SOLUTION

- On the app: four tabs plus More. On web: full sidebar. Use the same names everywhere.

RESIDUAL RISK None.

U9 Hindi and Marathi

PROBLEM English only.

SOLUTION

- Build translation support in from day one: no text hard-coded in screens, Devanagari-capable fonts, tests with long strings. Names stay in their original script.

RESIDUAL RISK Translations need human review.

U10 Two sources of truth

PROBLEM The PDF is static and the HTML prototype has the old theme and fake logic.

SOLUTION

- One design system: shared colour, type and spacing values plus a coded component library. Rebuild the prototype from it or retire it.
- Spec every screen with its states so developers have a handoff.

RESIDUAL RISK None.

8. Screens that must still be designed

These were missing from the first PDF. Each needs normal, empty, loading, error and offline states.

Screen	What it must do
Document viewer	All pages, page strip, zoom, version label, hash ID, comments pinned to page spots.
Placement editor (phone and web)	Full screen, magnifier drag, resize, rotate, snap, suggested zones, nudge, undo. See U2.
Approve with PIN or biometric	Shows what is being signed, level badge, remarks, wrong-PIN and locked states.
Request: Changes requested	Reason, pinned comments, edit and resubmit as new version.
Request: Rejected, Withdrawn, Expired	Clear final state with reason and a Copy as new request button.
Not the right person	Return or forward with a suggested role.
Out-of-office and delegation	Delegate, dates, preview of how the mark will read.
Document types and chains (admin)	Roles per step, modes, allowed actions, time limit, legal level.
Hierarchy: offices, roles, holders	Tree with start and end dates, acting holder, conflict marks.
Roster import and invitations	Upload list, validation errors, resend, pending verification.
Grants and approvals (admin)	Scoped roles, expiry, second-person confirmation.
Seals and stamps (owner)	Upload, two-person confirm, versions, revoke.
Forgot PIN, new device, device list	Password plus OTP, cooling-off notice, revoke device, emergency freeze.
Verification page (public)	Status, ID, approvers, times, upload a copy to compare. No content shown.
Certificate of completion	Timeline, hashes, seal, export.
Institution switcher and consent	Choose institution, privacy notice, terms.
Language and text size settings	English, Hindi, Marathi, larger text, Simple mode.
Stuck requests and audit (admin)	Reassign, escalate, filter and export.

9. Additional problems found

Things the first review missed.

A1 Bad networks and double taps

PROBLEM An approval could be sent twice, or an upload could fail halfway.

SOLUTION

- Idempotency keys so a repeated tap is processed once, resumable uploads, a clear pending state, and a queue for actions made offline.

RESIDUAL RISK Long offline periods still delay approvals.

A2 Two people editing at once

PROBLEM Two admins could change the hierarchy at the same time.

SOLUTION

- Version every record. If someone else changed it, show a prompt instead of silently overwriting.

RESIDUAL RISK None significant.

A3 Time and time zones

PROBLEM A phone clock can be wrong or changed.

SOLUTION

- The server time is the only time used. Store in UTC and show in India time.

RESIDUAL RISK None.

A4 Notification reliability and leaks

PROBLEM A missed alert stalls a request, and a notification could expose a document.

SOLUTION

- Push and email by default. WhatsApp or SMS for urgent items if the user opts in. Delivery tracking and retries.
- Notifications never contain document content. The in-app inbox is the source of truth. Quiet hours for authorities.

RESIDUAL RISK Third-party delivery is outside your control.

A5 Conversion fidelity

PROBLEM A DOCX can look different after conversion.

SOLUTION

- Convert on the server, embed fonts, and make the student preview the converted file before sending. Warn about differences.

RESIDUAL RISK Some complex layouts will still shift.

A6 Deletion versus audit trail

PROBLEM A user may ask for deletion while you must keep a record.

SOLUTION

- After content is deleted, keep only minimal audit data: IDs, times, hashes. State this in the privacy policy.

RESIDUAL RISK Ask a lawyer to confirm the wording.

A7 Students and staff who leave

PROBLEM Old accounts stay powerful.

SOLUTION

- Offboarding checklist, role end dates and an automatic reroute of pending requests. Alumni get read-only access to their completed documents for a set period.

RESIDUAL RISK Depends on admins keeping rosters up to date.

A8 Disputes

PROBLEM If a document is challenged, you need evidence.

SOLUTION

- A downloadable Certificate of Completion: timeline, approvers, document hash, seal, and device-proof hashes.

RESIDUAL RISK Courts decide weight. This only gives them a clean record.

A9 Your own staff

PROBLEM Platform staff could read documents.

SOLUTION

- No content access by default. Break-glass access needs a ticket, a reason and a second approver, and is logged and shown to the institution owner.

RESIDUAL RISK A malicious insider with key access remains a risk. Split key control.

A10 Phishing and fake apps

PROBLEM Attackers can send fake links or clone the app.

SOLUTION

- Links only from your official domain. Passkeys resist phishing. Official store listings. Show the real domain on the verification page.

RESIDUAL RISK Users can still be tricked. Teach them.

A11 Backups and uptime

PROBLEM Losing approvals or being down at a deadline hurts.

SOLUTION

- Encrypted backups with tested restores, a public status page, and recovery targets agreed with each institution.

RESIDUAL RISK Restores must be tested regularly or they are only a hope.

A12 Doing too much at once

PROBLEM Everything above is not a first release.

SOLUTION

- Build in phases (section 10). The first release proves the core flow on one department.

RESIDUAL RISK Scope creep is a habit. Review each phase before starting the next.

A13 Collusion and conflict of interest

PROBLEM Related people could approve each other.

SOLUTION

- Conflict rule from H1. Admins can mark relationships (for example a student whose parent is on the staff) so those pairs are blocked.

RESIDUAL RISK Unknown relationships cannot be detected by software.

A14 Screen readers and keyboards

PROBLEM A drag-only design excludes some users.

SOLUTION

- Every placement can be done with arrow keys or number fields. Draggable items have accessible labels and announcements.

RESIDUAL RISK Test with a real screen reader.

10. Build order

Doing everything at once is itself a risk. This is a suggested order, not a schedule.

Phase 0: Prove it is wanted

GOAL Prove demand and pick the pilot.

INCLUDES

- Interview about 5 professors and 20 students. Pick one department. Pick three document types, for example bonafide, leave and NOC. Get a lawyer view on the level each needs.

BEFORE MOVING ON Review the previous phase with real users before starting the next.

Phase 1: Safe core for one pilot

GOAL Make the core flow safe and usable.

INCLUDES

- Invite-only onboarding. Assigned roles. Document types with a sequential chain. Template boxes and simple placement. Document lock and hash. Marks applied by the server. Level 1 only. Device-key PIN. Audit log. Public verification page. Return, reject, withdraw. Reminders. Basic admin.

BEFORE MOVING ON Review the previous phase with real users before starting the next.

Phase 2: Real-world workflows

GOAL Handle messy real-world cases.

INCLUDES

- Parallel and any-one-of steps. Substitutes and escalation. Placement detection. Bulk approve for low-risk types. Hindi and Marathi. Extra notification channels. Certificate of completion.

BEFORE MOVING ON Review the previous phase with real users before starting the next.

Phase 3: Scale and strength

GOAL Grow and strengthen.

INCLUDES

- Level 2 and 3 signing through licensed providers. Self-serve institution onboarding. College login and ERP roster integration. Independent penetration test. Disaster recovery drills.

BEFORE MOVING ON Review the previous phase with real users before starting the next.

11. Decisions for you and the launch checklist

Things only you can decide, and the checks before real users.

Decisions for you

- Which institution and department will pilot, and who there will own it?
- Which document types, and which assurance level for each? (needs a lawyer)
- Hosting provider and region (data should stay in India).
- Who verifies new institutions and answers support?
- Price: decide only after the pilot shows real costs.
- Are under-18 students in scope? This affects consent rules.
- Web first, or app first? Authorities may prefer a link in email or WhatsApp.

Launch checklist

- Independent security review and penetration test.
- Abuse tests: fake authority, self-approval, replayed approvals, cross-institution reads, swapped files after approval.
- Usability test of the placement editor on small phones with real people.
- Test with five older faculty members on real phones.
- Accessibility check: contrast, screen reader, keyboard.
- Backup restore test.
- Legal sign-off on levels, privacy notice and retention.
- A small pilot with weekly feedback.

12. Closing note

This plan closes the problems we found. It does not make the product perfect. Some risks remain by their nature: people can be tricked, laws change, and the first real users will find things we did not. The honest way to deal with that is a small pilot, careful logging, quick fixes, and a willingness to change the plan when real use disagrees with it.